

Lista de verificação de controles e conformidade

Para preencher a lista de verificação de avaliação de controles, consulte as informações fornecidas no [relatório de escopo, metas e avaliação de riscos](#). Para obter mais detalhes sobre cada controle, incluindo o tipo e a finalidade, consulte o documento [categorias de controle](#).

Em seguida, selecione “sim” ou “não” para responder à pergunta: *A Botium Toys possui atualmente este controle implementado?*

Lista de verificação de avaliação de controles

Sim	Não	Controle
☐	☒	Menor privilégio
☐	☒	Planos de recuperação de desastres
☐	☒	Políticas de senha
☐	☒	Separação de funções
☒	☐	Firewall
☐	☒	Sistema de detecção de intrusão (IDS)
☐	☒	Backups
☒	☐	Software antivírus
☒	☐	Monitoramento, manutenção e intervenção manual para sistemas legados
☐	☒	Criptografia
☐	☒	Sistema de gerenciamento de senhas
☒	☐	Fechaduras (escritórios, loja física, armazém)

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Vigilância por circuito fechado de televisão (CFTV) |
| ☒ | ☐ | Deteção/prevenção de incêndio (alarme de incêndio, sistema de sprinklers, etc.) |

Para preencher a lista de verificação de conformidade, consulte as informações fornecidas no [relatório de escopo, metas e avaliação de riscos](#). Para obter mais detalhes sobre cada regulamentação de conformidade, revise a leitura sobre [controles, estruturas e conformidade](#).

Em seguida, selecione “sim” ou “não” para responder à pergunta: *A Botium Toys atende atualmente a esta boa prática de conformidade?*

Lista de verificação de conformidade

Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI DSS)

Sim	Não	Melhor prática
☐	☒	Apenas usuários autorizados têm acesso às informações de cartão de crédito dos clientes.
☐	☒	As informações de cartão de crédito são armazenadas, aceitas, processadas e transmitidas internamente, em um ambiente seguro.
☐	☒	Implementar procedimentos de criptografia de dados para proteger melhor os pontos de contato e dados de transações de cartão de crédito.
☐	☒	Adotar políticas seguras de gerenciamento de senhas.

Regulamento Geral sobre a Proteção de Dados (GDPR)

Sim	Não	Melhor prática
☐	☒	Os dados dos clientes da U.E. são mantidos privados/protegidos.

- | | | |
|-------------------------------------|-------------------------------------|---|
| ☒ | ☐ | Há um plano em vigor para notificar os clientes da U.E. dentro de 72 horas se seus dados forem comprometidos/houver uma violação. |
| ☐ | ☒ | Garantir que os dados estejam devidamente classificados e inventariados. |
| ☒ | ☐ | Aplicar políticas, procedimentos e processos de privacidade para documentar e manter os dados adequadamente. |

Controles do Sistema e da Organização (SOC tipo 1, SOC tipo 2)

Sim	Não	Melhor prática
------------	------------	-----------------------

- | | | |
|-------------------------------------|-------------------------------------|---|
| ☐ | ☒ | As políticas de acesso do usuário estão estabelecidas. |
| ☐ | ☒ | Dados sensíveis (PII/SPII) são confidenciais/privados. |
| ☒ | ☐ | A integridade dos dados garante que eles sejam consistentes, completos, precisos e tenham sido validados. |
| ☐ | ☒ | Os dados estão disponíveis para indivíduos autorizados a acessá-los. |

Recomendações: Recomenda-se que a Botium Toys implemente com urgência a criptografia dos dados sensíveis e das transações de pagamento para atender aos padrões do PCI-DSS e do GDPR. Além disso, é fundamental aplicar o princípio do menor privilégio, exigir autenticação multifator (MFA) e estabelecer políticas formais de senhas e resposta a incidentes para mitigar os riscos operacionais.